

R29

HTB · STARTING POINT

HTB Starting Point — Sequel

Programación para Ciberseguridad · Fase III · AD2026

MySQL es el servidor de base de datos más extendido del mundo. Sin autenticación configurada o con credenciales por defecto, un cliente de línea de comandos como `mysql` da acceso completo a todas las bases de datos del servidor.

Objetivo: Conectarse a un servidor MySQL sin autenticación desde la terminal, enumerar las bases de datos y recuperar la flag.

Acceso a la plataforma

Ve a Starting Point → Tier 1 → Sequel e inicia la máquina.

Pistas de enfoque

Escanea con `nmap`. Conéctate con `mysql -h <IP> -u root` (sin contraseña). Dentro, usa `show databases;`, `use <db>;`, `show tables;` y `select * from <tabla>;` para encontrar la flag.

Evidencias requeridas

- Screenshot de la conexión a MySQL sin contraseña.
- Screenshot de la navegación por las bases de datos y la flag encontrada.

Preguntas de reflexión

1. ¿Cómo automatizarías con Python (usando la librería `mysql-connector-python`) la búsqueda de credenciales por defecto en MySQL contra una lista de 100 servidores?
2. Sequel usa MySQL; Mongod (R18) usa MongoDB. Ambos permiten acceso sin credenciales. ¿Qué diferencia fundamental hay entre una base de datos relacional y una NoSQL desde el punto de vista de la estructura de la información que exponen?
3. Si encuentras un servidor MySQL accesible sin contraseña durante una auditoría autorizada, ¿cuáles son los tres primeros comandos que ejecutarías para evaluar el impacto de la exposición?